IONITY GLOBAL

(Pty) Ltd

Ionity NoteCad

POPIA Compliance Assessment

Version 1.1: the action audit and the fixes

Personal information · Live checks · The eight conditions · Findings and fixes

DOC-2026-10-NOTECAD-POPIA-01 | Version 1.1 | 29 October 2026

CONFIDENTIAL

www.ionity.today | ai@ionity.today

Index – Table of Contents

Nine sections and one appendix: the summary, what changed since v1.0, the action register, each POPIA condition, data subjects' rights, special topics, the tests, and what still needs a person to decide.

Section	Topic	Page
1	Summary	–
2	What changed since v1.0	–
3	Scope, method and limits	–
4	The action register	–
5	The eight conditions (sections 8-25)	–
6	Data subjects' rights (sections 23-25)	–
7	Special topics	–
8	Tests and checks	–
9	What needs a person to decide	–
A	Appendix A - Document control	–

Note: Page numbers are indicative. Actual pagination depends on rendering and may shift slightly between Word versions. Use Word's Navigation Pane (View > Navigation Pane) for live navigation.

1. Summary

This is version 1.1 of the technical POPIA compliance test of Ionity NoteCad (POPIA, Act 4 of 2013). It follows the 29 October 2026 review (v1.0), which found four areas not yet compliant and listed twelve fixes. All twelve that can be done in code are now built and tested, and every action NoteCad takes on personal information is in a register generated from the code. Nothing here is legal advice.

Overall: in code, NoteCad now meets the eight conditions as far as software can. **133 actions: 120 compliant, 13 need a person to decide.** What remains is organisational: registering an Information Officer, operator agreements with the cloud services, the lawful-basis wording for the notice, a legal review of the notice, retention periods on the real workspaces, and encrypting the disk of the PC that holds the data (section 9).

Area	v1.0	v1.1	What decides it now
Accountability (s8)	Partly	Human	Information Officer named in the notice; registration with the Regulator is Ionity's
Processing limitation (s9-12)	Partly	Human	notice before the first note; the lawful-basis wording needs a practitioner
Purpose specification (s13-14)	Gap	Meets	retention periods per workspace, purged every 6 hours on every brain
Further processing (s15)	Meets	Human	employees' words stay in their own companion store; LoRA training is a decision
Information quality (s16)	Meets	Meets	edit, undo, the recording behind each note
Openness (s17-18)	Gap	Meets	privacy notice on desktop and phone, read before the first note
Security safeguards (s19-22)	Partly	Human	TLS pinning, tickets, Keystore, headers, security log, breach runbook; disk encryption on WABAKIPI is open
Data subject participation (s23-25)	Partly	Meets	a copy and erasure for one person, member or not
Cross-border transfer (s72)	Partly	Human	the cloud gate is off by default; operator agreements before an owner turns it on

2. What changed since v1.0

Finding (v1.0)	Built	Proof
1 No retention limit	per-workspace periods (recordings, transcripts, activity log); worker purge; archive period	test_old_recordings_transcripts_and_log_go_new_ones_stay
2 Deleted data lived on	journal compaction; tombstones without data; companion forgets	test_a_deleted_workspace_leaves_only_tombstones_in_the_journal
3 Tokens in the access log	10-minute tickets; rotating log with tokens, tickets and invite codes blanked; invite preview by POST	test_the_log_never_holds_a_token_a_ticket_or_an_invite_code; e2e popia.spec
4 Plain HTTP on the LAN	HTTPS on :9788 with the brain's own certificate, pinned by the phone (WebView and uploads); no cleartext	test_the_lan_certificate_is_made_once_and_pinned; TlsPinTest
5 No privacy notice	notice v2 (officer, monitoring, cloud), read before the first note	test_a_member_records_nothing_before_reading_the_notice; e2e popia.spec

Finding (v1.0)	Built	Proof
6 No per-person access and erasure	a copy for the person or an owner; erasure by an owner across every copy	test_erasing_a_person_removes_them_everywhere_but_the_audit_record; e2e
7 Unencrypted database	start-up warns when the drive is not encrypted (WABAKIPI: it is not)	status table; human action 7
8 Phone token in plain storage	Android Keystore (AES-GCM), out of the WebView's storage	TokenVaultTest
9 No security headers	CSP, frame, nosniff, referrer, no-store	test_answers_carry_security_headers_and_refusals_are_logged
10 Logs never rotate	weekly, four weeks kept	serve.py
11 This PC needs no token	kept for one user; the status table says how to turn it off	status table
12 No cloud gate	off by default, owner per workspace, logged; restricted branches never leave	test_no_note_leaves_this_pc_while_the_gate_is_off
Found in the audit	a worker's health or disciplinary details held for the owners	test_a_note_with_a_workers_health_is_held_for_the_owners

3. Scope, method and limits

Item	Detail
Code	Ionity_NoteCad_AI, main at 301a3c4 (and the commits after it for this report)
Method	the register (tools/popia_inventory.py) lists every route of the brain and the companion, every spoken admin command, background thread, synced table and app action; each is matched to a rule with its evidence, and CI fails when one is missing
Live	WABAKIPI: the stack on the new code, the field test, three full Playwright runs
Not covered	contracts, registrations and legal wording (section 9); iOS; a real Android phone (CI builds and unit-tests it)

4. The action register

docs/compliance/popia-action-register.md, generated from the code. Summary by surface:

Surface	Actions	Compliant	Needs a person
Brain endpoints	75	67	8 (sync with a hub or Supabase, the privacy notice wording)
Companion	15	14	1 (LoRA training)
Spoken admin commands	3	3	-
Background threads	4	3	1 (sync to a hub)
Synced tables	19	19	-
Files, logs and copies	5	2	3 (archive period, disk encryption, Google Drive)
App actions (desktop 5, phone 7)	12	12	-

The numbers per surface are as generated on 29 October 2026; the register itself is the source of truth.

5. The eight conditions (sections 8-25)

Condition	Verdict	Evidence
1 Accountability (s8, s55)	Human	Information Officer in the notice (the owner by default); security log; register
2 Processing limitation (s9-12)	Human	only what is said is kept; no location, contacts or IDs; notice before the first note; objection through the contact; lawful-basis wording open
3 Purpose specification (s13-14)	Meets	periods cover recordings, transcripts, the activity log, the companion's memory, the sync journal on the PC and a Supabase hub, phone copies (through pull) and archives
4 Further processing (s15)	Human	companion learns per person; LoRA training a decision
5 Information quality (s16)	Meets	edit and undo; the recording behind each note; corrections through the contact
6 Openness (s17-18)	Meets	notice v2, read before the first note; the register
7 Security safeguards (s19-22)	Human	hashed tokens, tickets, pinned TLS, Keystore, headers, throttled join, revoke-and-wipe, security log, breach runbook; disk encryption on WABAKIPI open
8 Data subject participation (s23-25)	Meets	a copy and erasure for one person; workspace export and deletion

6. Data subjects' rights (sections 23-25)

Right	How	Kept on purpose
Access (s23)	People & seats or the phone menu: a copy of everything about the person (member, devices, recordings listed, notes naming them, what they did, what the companion learned)	-
Correction (s24)	edit the note or name; ask the owner through the notice's contact	-
Deletion (s24)	an owner erases a member or a person on the map: recordings deleted, names replaced by [removed] everywhere, devices wiped, companion forgets, journal compacted; reaches phones and hubs as updates	the action log rows (who did what, when), with the name taken out; archives until their period
Objection (s11(3))	through the notice's contact, to the owner	-

7. Special topics

Topic	Finding
Special information (s26-33)	a note naming a person with health, disciplinary, union or religious details is held for the owners instead of being filed on an open branch; notes about animals and machines are not affected
Biometrics	voice is recorded, never used to identify anyone: no speaker identification in the brain or the companion

Topic	Finding
Children (s34-35)	no ages are collected; the owner confirms no children use it (human action 11)
Direct marketing (s69)	none: NoteCad sends nothing to anyone outside the business
Automated decisions (s71)	routing and delegation file notes and tasks; nothing decides about a person with legal effect, and held or refused changes go to a person
Workplace monitoring	the notice says what is recorded at work; employees see their own activity and can get their own copy
Transfers abroad (s72)	the gate is off by default and per workspace; a note about a restricted branch never leaves, gate on or not; each transfer is logged

8. Tests and checks

Check	Before (v1.0)	Now
Brain tests (SQLite on WABAKIPI)	169	193 (24 new: test_popia, test_popia_actions)
Companion tests	47	48
Desktop (Vitest)	37	40
Phone (Vitest)	7	10
Android unit tests (CI)	13	TlsPinTest and TokenVaultTest added
CI (Postgres 17, Supabase 0001-0009 twice, APK, Tauri)	green	green, plus the register check
Field test (golden notes)	20/21	20/21 (95.2 %), showcase 3/3
Playwright	21 + roles	every spec plus popia.spec (notice before notes, erasure, URLs and log), three full runs

9. What needs a person to decide

#	What	Who
1	Register Ionity's Information Officer; publish the PAIA manual	Ionity
2	Operator agreements with Anthropic, Deepgram, Supabase, Google; Supabase region	Ionity
3	Lawful basis per purpose in the notice (legal wording)	Ionity with a practitioner
4	Legal review of the notice and the monitoring paragraph	Ionity with a practitioner
5	Retention periods on the real workspaces (suggested 90 / 365 / 365 days)	Each owner
6	NC_BRAIN_ARCHIVE_DAYS for data\archive on WABAKIPI	Dennis
7	Encrypt the disk with data\ (Windows 11 Home: Device Encryption or Pro + BitLocker)	Dennis
8	Whether per-owner LoRA training goes ahead	Ionity
9	Own the breach runbook (who decides, who tells the Regulator)	Ionity and each owner

#	What	Who
10	Turn the cloud transfer on only after 2 and 3	Each owner
11	Confirm no children use the app	Each owner

Details and reasons: docs/compliance/popia-human-actions.md. Breach steps: docs/compliance/breach-runbook.md.

Appendix A - Document control

Field	Value
Document	Ionity NoteCad - POPIA compliance assessment
Document ID	DOC-2026-10-NOTECAD-POPIA-01
Version	1.1, 29 October 2026 (1.0: 29 October 2026)
Prepared by	Dennis Grobler (Wabakipi), with Claude Code | Ionity Global (Pty) Ltd | AEDI
Governance / licence	Policy 986 AED | License AED 900
Rights	(c) 2026 Ionity Global (Pty) Ltd - All rights reserved
Company	IONITY GLOBAL (Pty) Ltd 2026/276325/07 | www.ionity.today | ai@ionity.today
Note	technical assessment, not legal advice; confirm sections 5, 7 and 9 with a POPIA practitioner

Building Tomorrow, Today. | Anything is Possible with God.